Lập trình mạng · Chương 5

Bảo mật: xác thực và phân quyền với OAuth 2.0 và JWT

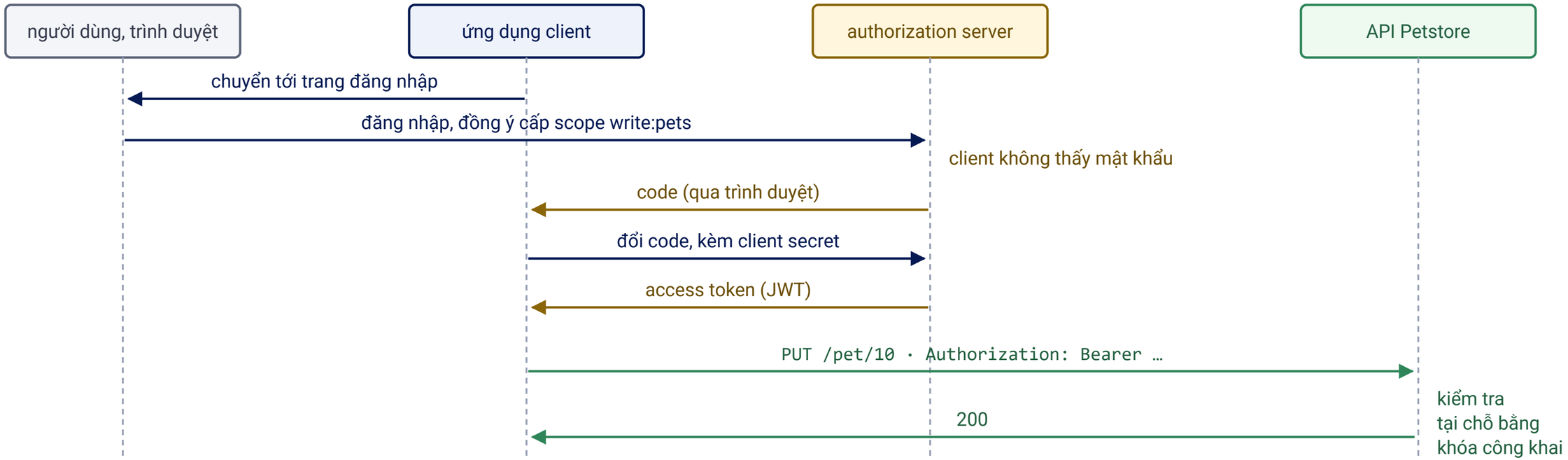
TS. Đặng Ngọc Hùng

Ai đang gọi, và được làm gì?

1. TLS xác thực **server**, chưa cho biết **ai** đang gọi API
2. **Xác thực**: người gọi là ai; **phân quyền**: người đó được làm gì
3. Không gửi mật khẩu theo mỗi request: API kiểm tra **access token** do một bên chuyên trách cấp

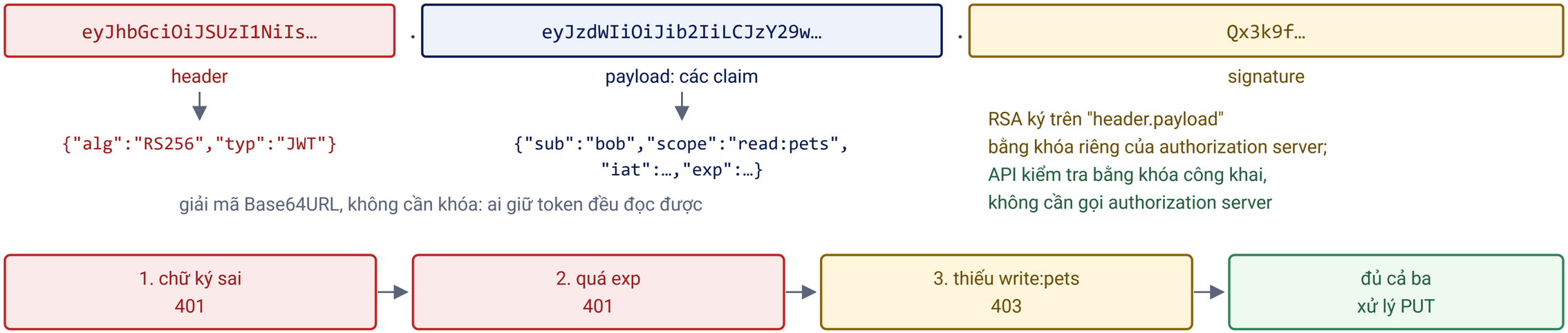
> **Câu hỏi của phần:** OAuth 2.0 cấp token thế nào, và API kiểm tra JWT ra sao trước khi tin?

OAuth 2.0: authorization server cấp access token, API chỉ kiểm tra token



OAuth 2.0: authorization server xác thực người dùng và cấp **access token** với **scope**; API chỉ kiểm tra token.

JWT: header, payload và chữ ký; API kiểm tra trước khi tin



401: chưa xác thực được (không có token, token không hợp lệ) · 403: đã xác thực nhưng không có quyền

JWT: header.payload.signature; **chữ ký số** chống sửa đổi, **claim** exp giới hạn thời hạn, **scope** quyết định quyền.

Kiểm tra JWT bằng JDK: thuật toán, chữ ký, rồi thời hạn

```java
if (!"RS256".equals(Json.parse(decode(parts[0])).get("alg"))) {  // không nhận "alg":"none" hay thuật toán khác
rsa.initVerify(key);  // chỉ cần khóa công khai: không gọi authorization server
rsa.update((parts[0] + "." + parts[1]).getBytes(US_ASCII));
if (!rsa.verify(DEC.decode(parts[2]))) {  // 1. chữ ký: payload có bị sửa không
if (Long.parseLong(claims.get("exp")) <= Instant.now().getEpochSecond()) {  // 2. thời hạn
```

- Chỉ nhận thuật toán đã định (RS256), không nhận `alg` là `none`
- Kiểm tra **chữ ký số** bằng khóa công khai trước khi tin claim
- So exp với thời điểm hiện tại: token hết hạn bị từ chối

API trả 401 khi token không hợp lệ, 403 khi thiếu quyền

Java

```
claims = Jwt.verify(auth.substring("Bearer ".length()), authServerKey);  // xác thực: token có hợp lệ không
} catch (Jwt.InvalidTokenException e) {
    send(ex, 401, message(e.getMessage()));
if (!Set.of(claims.get("scope").split(" ")).contains("write:pets")) {  // phân quyền: có được sửa không
    send(ex, 403, message("insufficient scope"));
```

Kết quả chạy

```
no token                    -> 401 {"message":"missing token"}
valid token, write:pets     -> 200 {"id":10,"name":"doggie","status":"sold"}
expired token               -> 401 {"message":"token expired"}
tampered payload            -> 401 {"message":"bad signature"}
valid token, read:pets only -> 403 {"message":"insufficient scope"}
```

Payload của JWT không được mã hóa: ai giữ token cũng đọc được

```java
System.out.println("header  " + Jwt.decode(parts[0]));  // không cần khóa
System.out.println("payload " + Jwt.decode(parts[1]));
```

Kết quả chạy

```
token   470 chars: eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJib2IiLCJzY29...
header  {"alg":"RS256","typ":"JWT"}
payload {"sub":"bob","scope":"read:pets","iat":1792952026,"exp":1792952326}
signature 342 chars (RSA 2048 bit)
```

- Payload chỉ được **biểu diễn** bằng Base64URL, không được **mã hóa**: chữ ký chống sửa, không che nội dung
- Không đặt dữ liệu bí mật trong JWT; luôn gửi token qua TLS

Câu hỏi 1

API trả 403 cho một request PUT có kèm access token. Điều đó cho biết gì?

A. Request không có token.

B. Token hợp lệ, server biết người gọi là ai, nhưng người đó không có quyền ghi.

C. Chữ ký của token sai.

D. Token đã hết hạn.

Câu hỏi 1

API trả 403 cho một request PUT có kèm access token. Điều đó cho biết gì?

A. Request không có token.

B. Token hợp lệ, server biết người gọi là ai, nhưng người đó không có quyền ghi.

C. Chữ ký của token sai.

D. Token đã hết hạn.

403 là lỗi phân quyền: xác thực đã thành công nhưng thiếu quyền (scope). Không có token, sai chữ ký, hết hạn đều là lỗi xác thực, trả 401.

Câu hỏi 2

API nhận 1 000 request mỗi giây, mỗi request mang một JWT. Để kiểm tra token, API có cần gọi authorization server cho từng request không?

A. Có, vì chỉ authorization server biết token có hợp lệ.

B. Có, để giải mã payload.

C. Không, vì JWT không cần kiểm tra.

D. Không, API kiểm tra chữ ký bằng khóa công khai và tự đọc exp, scope trong token.

Câu hỏi 2

API nhận 1 000 request mỗi giây, mỗi request mang một JWT. Để kiểm tra token, API có cần gọi authorization server cho từng request không?

A. Có, vì chỉ authorization server biết token có hợp lệ.

B. Có, để giải mã payload.

C. Không, vì JWT không cần kiểm tra.

D. Không, API kiểm tra chữ ký bằng khóa công khai và tự đọc exp, scope trong token.

JWT mang sẵn claim và chữ ký; API kiểm tra chữ ký bằng khóa công khai của authorization server rồi đọc exp, scope ngay trong token.

Tổng kết

1. **Xác thực**: người gọi là ai (lỗi: 401); **phân quyền**: người đó được làm gì (lỗi: 403)

2. **OAuth 2.0**: authorization server cấp **access token** với **scope**; API không giữ mật khẩu

3. **JWT**: kiểm tra chữ ký, exp, scope trước khi tin **claim**; payload không được mã hóa

Từ khóa cần nhớ xác thực · phân quyền · OAuth 2.0 · access token · JWT · claim · scope

Mở rộng

Chủ đề nâng cao

- PKCE cho ứng dụng không giữ được bí mật
- Thu hồi token và refresh token

Bài tập mở rộng

Thêm kiểm tra scope read:pets cho request GET, như đặc tả OpenAPI của Petstore quy định.

Tiếp theo

Hiệu năng: lời gọi không chặn với CompletableFuture và gRPC async stub